

DCM Test 4

Day 1: April 8th

The sad Reality:

- The battle between achieving desired behaviors vs preventing undesired behaviors
 - the first always wins
- People are obsessed with providing more functionality
 - security is secondary (no functionality = no product = no need for security)
 - security is after thought (organizations have dedicated security team)
- managing the trade-off between functionality and security
 - from the beginning

What is Cybersecurity?

- marketing word for security and privacy
 - computer security
 - network security
- Cyber is needed everywhere
 - engineer, scientist, businesses
 - computer system, network, information system

Cybersecurity is NOT CYBER (yikes)

The CIA Triad

- Confidentiality
 - keep the secret secret
 - in cloud: hide user's sensitive/private information
- Integrity
 - guard the secret unchanged
 - in cloud: keep users' data unchanged
- Availability
 - timely and reliable access
 - in cloud: keep the cloud services up and running

Three More A's

- Authentication
 - confirm someone's identity
 - make sure the one who use/modify the system is legit and verifiable
- Authorization
 - confirm someone's permission
 - keep track of which resource one can access
- Accounting
 - system log
 - keep track of who access each resource

Risks:

- What happened if the CIAAAA contradict with eachother?
 - you have to manage/accept the risks
- Formula
 - $\text{risk} = \text{likelihood} \times \text{impact}$

Threat Modeling

- Identifying Assets: Determining which parts of your system (data, services, components) need protection
- understanding the architecture: create diagrams or models that represent the flow of data and interactions between system components
- recognizing threats: systematically brainstorming potential attack vectors and vulnerabilities (for example, through methodologies like STRIDE or PASTA).
- Assessing risks: evaluating the likelihood and potential impact of each threat to prioritize which ones require immediate attention
- Defining Mitigation Strategies: developing and implementing countermeasures to reduce or eliminate the risks associated with the identified threats

Risk Management:

- the goal of any information security program is to reduce risk to an acceptable threshold
- in the end you really only have three choices
 - reduce the likelihood
 - reduce the impact
 - accept the risk

Other key concepts

- vulnerability

- weak points in the system
- Exploits
 - vulnerability that can be taken advantage by attacker
- Threat
 - circumstances than cause negative damage to systems
- Attack vectors
 - methods to attack
- attack surface
 - collection of system components that can be exploited by attackers
- attack
 - actions of exploiting vulnerabilities

Why attack?

- mess w someones system
- goal:
 - theft: collect sensitive inforamtion about victims
 - Espionage: monitor victim's activity and resource utilizations
 - sabotage: destroy (functions of) the victim's system

Malicious actors:

- neophytes: noob attackers
 - no sophisticated attacks
- Independent actor: hobby attackers
 - know what they are doing, like to mess with others system
- Hacktivist: professional hackers
 - further social/political stands, anonymous
- Organized crime: money makers
 - demand money for successful attack
- Advanced Persistent Threats (APT)
 - Gov/international attackers or cyber warefare

Several Attack Methods

- Malware:
 - rootkit, ransomware, cryptojacking, botnet, etc
 - Distributed via network and installed on victims systems

Social Engineering

- phishing, spamming, baiting, scareware, etc

Hacking vs Insider Threat

- Hacking: gain access to systems from outside of an organization
- Insider threat: gain access to system from inside of an organization

Adversarial Thinking

- The bad guys don't follow the rules
- To understand how to secure a system, you have to understand what types of attacks are possible including their requirements and effects
- Note that that is not the same as actually launching them
 - things we learn in class are vulnerabilities in real-world system
 - in the homework, you must explicitly state that you will not apply anything learned in class to real world situations

Computer Security

- functionalities
 - host applications
 - hold information
 - easily accessible (through network)
 - large attack surface
- Computers make money
 - for you
 - for the bad people

Threats in security:

- system
 - malware, privilege escalation, stolen credentials
- Information
 - leaking/tampering data
 - unauthorized access
- Software
 - injection attack
 - buffer overflow
 - software supply chain
- Side Channel/covert-channel attack
- social engineering

Countermeasures:

- system security:
 - authentication
 - encapsulation
 - isolation
 - anti-virus
 - system logging
- Information security
 - encryption
 - access control
- Software Security
- software updates
- software/source code audit
- software approval
- Education
- cybersecurity training

Network security:

- internet is dangerous
- network security guarantees(?) that all devices can only obtain information that they are authorized
 - prevent unauthorized access
 - securing data
 - reduce service interruption

Threats in network security

- eavesdropping
 - monitoring communication between users
- Data modification
 - changing data in network packets
- Man in middle
 - eavesdropping + data modification
 - identity spoofing
- Network spoofing
- pretend to have a legitimate ip
- Distributed denial of services
- prevent normal user of service

Countermeasures:

- protecting data
 - cryptogaphy
 - data loss prevention (DLP)
- Protecting Network
 - firewlaal
 - intrusion detection system
 - intrusion prevention system
- Network logging
 - network tap

Physical security:

- Data centre risk management
- pest control
- do you have pest control program for your data center?

What are the most effective way to defend your system?

Countermeasures:

power off your system/server

cut network connection

(to ensure it will never get hacked / the attack will stop)

Day 2: April 13th

Cryptography:

- greek for hidden and writing is a means of transforming data in a way that rendres it unreadable by anyone except the intended recipient.
- cryptography may offers
 - confidentiality - keeping the data secret
 - integrity - detect any unauthorized data changes
 - authenticity - ensure the source of the data is legitimate
 - nonrepudiation - guarantee that the source cannot deny the data
 - access control - primarily used in blockchain to ensure who can access to what resources
- Two types

- block cipher - must encrypt block by block; padding/waiting; (roller coaster)
- stream cipher - encrypt as data flows; no padding; (waiting in line)

Legacy Encryption System

- substitution cipher: convert one letter to another
- Transposition cipher: change position of letter in text; word jumble
- monoalphabetic cipher: caesar
- polyalphabetic cipher: Vigenere
- Modular mathematics: running key cipher
- one time pads: randomly generated keys
- The only cipher that can achieve unconditionally secure is One-time pad
 - all other ciphers are computationally secure

Cryptographic Methods

- symmetric
 - same key for encryption and decryption
 - key distribution problem
- Asymmetric
 - mathematically related key pairs for encryption and decryption
 - public and private keys
- Hybrid
 - combines strengths of both methods
 - Asymmetric distributes symmetric key; also known as a session key
 - symmetric provides bulk encryption
 - example: SSL negotiates a hybrid method

At Rest Encryption

- data should be encrypted when they are stored in cloud server (at-rest encryption)
 - AES is typically used for the encryption (symmetric encryption)
- Each chunk is encrypted at the storage level with an individual data encryption key (DEK)
 - two chunks won't have the same DEK
 - even if they are owned by the same client
 - if data is updated, it is encrypted with a new key
- DEKs are encrypted with a key encryption key (KEK)
 - one or more KEKs exist for each service
- this is not the same as a customer-applied encryption

In transit encryption:

- data should be encrypted when they are in transit to/from cloud server (in transit encryption)
 - follows the network security standard: TLS
- TSL flow
 - initiation: client initiates the TLS handshake to the server
 - Client Hello: information about the TLS versions it supports, the cipher suites (encryption algorithms) it can use, and other parameters
 - server Hello: indicate TLS version and cipher suite, along with its own parameters
 - Certificate Exchange: server sends its digital certificate to the client, which contains the server's public key and other information about the server's identity
 - Certificate Verification: the client verifies the server's certificate on Certificate Authority (CA)
 - Key exchange: the client and server use the server's public key to agree on a shared secret key (aka session key)

Hypervisor (and VMI) Knows everything

- when you send data to the cloud for processing (storage, analytics, AI) you're usually doing one of these:
 - Encrypting it for storage, but decrypting it before processing - risky!
 - trusting the cloud provider with sensitive info - like health records, finances, personal photos
- This creates major concerns
 - data breaches (if the cloud is hacked)
 - insider threats (cloud admins seeing private data)
 - regulatory compliance (HIPAA, GDPR)
 - Inability to outsource sensitive tasks
- how to keep data encrypted at all time, even during data processing

Homomorphic Encryption (HE):

- HE allows computations on encrypted data without ever needing to decrypt it!
- Homomorphic encryption lets you
 - encrypt data
 - perform operations on that encrypted data (addition, multiplication)
 - decrypt the result, and you'll get the same answer as if you had done the operation on unencrypted data
- Equation representation
 - assume $X+Y = Z$, with HE we can perform the calculations as

- $ENC(x) + ENC(y) = ENC(Z)$
- $ENC(Z)$ can be decrypted as
- come back

Unpadded RSA for HE:

- if the RSA public key as modulus n and encryption exponent e , then the encryption of a message is given by
 - $e(m) = m^e \bmod n$.

Paillier cryptosystem

https://en.wikipedia.org/wiki/Homomorphic_encryption

Types of HE

- partially homomorphic encryption (PHE)
 - support only 1 operation (addition or multi)
 - simple voting systems, taxes
- Somewhat homomorphic encryption (SHE)
 - limited number of operations
 - light analysis
- Fully homomorphic encryption
- any number of operations

Searchable encryption (SE)

- searchable encryption allows you to search encrypted data without decrypting it first.
 - you encrypt your files or database and upload it to the cloud
 - later, you can search for a specific keywords or patterns without revealing the contents to the cloud provider
- One simple implementation
 - user encrypts files and keywords, uploads them to the cloud
 - user generates a search token for a keyword, this token is encrypted but still allows the cloud to match it against encrypted keywords
 - the cloud uses the token to find matching encrypted documents, returns results (still encrypted) to the user
 - user decrypts the final results locally
- How to protect the information of keyword -> data link?

Zero knowledge proof

- users can prove their identity without revealing their actual secret to the system.
- how it works
 - the user registers securely by providing a public commitment to their secret
 - during login, the user generates a cryptographic proof using their secret.
 - the server verifies the proof without ever seeing the secret itself
 - the proof is valid, access is granted

The Ali Baba Cave

- peggy has uncovered the secret word used to open a magic door in a cave ("Open sesame")
 - victor wants to know whether peggy knows the secret word
 - peggy does not want to reveal her knowledge to victor but want to prove that they really know the password

Victor build a ring cave, with the entrance on one side and the magic door blocking the opposite side

- label them as A or B
Victor waits outside the cave as peggy goes in
- peggy takes either a or b
- victor is not allowed to see which path she takes
Victor enters the cave and shouts the name of the path he wants her to use to return
- chosen at random

If scenario two;

- if peggy really does know the magic word, this is easy: she opens the door if necessary, and returns along the desired path
- Since victor would choose A or B at random, she would have a 50% chance of guessing correctly
 - Repeat this trick many times, her chance of successfully anticipating all of Victor's requests would be approximately 0.
 - If Peggy repeatedly appears at the exit Victor names, then he can conclude that it is extremely probable that Peggy does, in fact, know the secret word.

DAY 3: April 15th

knowing your neighbor

- attackers always want to know what you are up to, and they don't want to get caught
 - traditional hacking methods may not be a good way: highly likely to get caught
 - is there a way to extract info without the need of hacking?
 - is there a way to send info without the need of monitored infrastructure
- Yes to both
 - side channel attack: steals information from a victim by observation
 - Covert channel attack: sends secret data between two parties without the use of internet

Side channel attack

- attacks based on information that can be inferred from the physical implementation of a system, rather than breaking its theoretical properties
 - how long, how fast, how hot
 - initially most commonly discussed in the context of crypto systems
 - but also prevalent in many contexts
- popular side channel attack on crypto system
 - timing attacks
 - power analysis
 - if you do something different for secret key bits 1 vs 0, attacker can learn something

Side channel attack examples

- timing attack on software optimization
 - RSA: Leverage key-dependent timings of modular exponentiations
 - Block ciphers: leverage key-dependent cache hits/misses
- Power attack on hardware optimization
 - simple power analysis: directly read off bits from powerline traces
 - Differential power analysis: look for statistical differences in power traces, based on guesses of a key bit.

Instruction Speculation

- instruction speculation is when a CPU guesses ahead and starts executing instructions before it knows for sure they're needed, to speed things up.
 - "I think this branch will be taken, so I'll start working on it early. If I'm right - we save time. If I'm wrong we undo the work"
- Example: if (x>0): doA(); else: doB();
 - the CPU doesn't want to wait to evaluate x>0
 - instead it speculatively executes one of the branches (say, doA())

- if later it finds out the guess was wrong, it rolls back the speculative work, like it never happened.

Cache Timing Attack:

- Basic idea: manipulate cache to a known state, wait for victim activity, then examine what has changed.
- Example: "Flush and reload"
 - Flush relevant addresses from cache
 - wait for victim
 - reload relevant addresses, time accesses
 - if timing was fast, victim accessed relevant address; if timing was slow, victim did not.

Both of these leads to spectre

- train branch predictor to follow one branch of conditional
- after training, make the followed branch access information that the code should not be allowed to access
- the secret information affect which part of array2 is loaded into the cache
- after the hardware determines that the branch was incorerectly executed, the logic of the program will be rolled back but the cache will stilll be impacted
- time reads to cache for access to array2 to see which cache lines are read more efficiently

Threats in cloud computing

- Cross VM attacks
 - attacker runs a VM on the same hosts as the victim (multi latency)
 - measures shared resour
- COMEBACK

Covert channel attack

- communicate info between tw ocomputer processes that are not allowed ot communicate, by hiding info into shared resources
 - bypass security policy by malicious compromised computer processes
 - evade surveillance
 - bypass communication restrictions
- Hiding methods
 - storage channel: data transmitted by writing or abstaining from writing, eg writing into RAM

- Timing Channel: data modulated into the timing, or occurrence of events, eg the times between network packets

Local channels:

- shared resources in VM:
 - cpu, ram, disk, network
- CPU Cache-based covert channel
 - one vm modulates data by accessing or not accessing shared cache lines.
 - another VM measures cache timing to decode the signal
- disk IO covert channel
 - A vm causes disk contention to transmit signals
 - B Vm measures disk access latency or file write lock

Remote network channels

- shared resources in communication channel
 - timing: packet timings
 - storage: packet headers
 - packet payload: steganography
- HTTP header manipulation
 - hide data in uncommon HTTP headers like User-Agent, Cookie, or referrer
- Packet Timing (timing channel)
 - Vary the timing between packets to encode bits of data.
 - send packet every 100ms = bit 0; send packet every 300ms = bit 1

TCP/IP header covert channel

- TCP IP header can serve as a carrier for a covert channel
 - these header fields are ignored in processing packets

Other Network Channels

- ICMP echo request/reply can tunnel arbitrary user data
- DNS can hold arbitrary text in its various fields, high bandwidth 110-220 bytes per request

Timing channels

- information is hidden by triggering or delaying events at specific time intervals

Day 4 April 20th

Timing channels:

- info is hidden by triggering or delaying events at specific time intervals

Coresidency

- coresidency refers to the situation where virtual machines belonging to different customers, are placed on the same physical host within a cloud provider's infrastructure
- why study co-residency
 - security risks: side-channel attacks - attackers might deliberately try to place their VM on the same host as a target VM to enable co-residency and potentially launch side channel attacks.
 - performance impacts: resource contention - if 1 VM is resource intensive, it can degrade the performance of others on the same host
- What's need to be done? these are also defense strategies
 - map cloud infrastructure
 - predict where the target VM reside
 - establish coresidency
 - launch an attack

Attackers can also set up a large number of instances, hoping that some can achieve coresidency

Amazon EC2

- anyone with a valid credit card can create an EC2 account. By default accounts are limited to 20 concurrent linux instances
- Amazon EC2 User options
 - region
 - Availability zone: each region has 3 availability zones; each availability zone has independent failure modes such as separate power and network connectivity from the other availability zones
 - Instance type: the instance type indicates a particular combination of computational power, memory, and storage for instance
- M1.small; c1.medium; m1.large; m1.xlarge; c1.xlarge

Amazon EC2

- ip addressing for EC2

- internal: each instance receives an internal IPv4 address and domain name
- External: each instance also receives an external IPv4 address and domain name
- Cloud cartography: mapping the cloud infrastructure to better predict and facilitate co residency with a target
 - domain mapping: within the cloud, both the external and internal domain name map to the internet IP address. Outside the cloud, the external domain is mapped to the external IP addresses
 - amazon is more likely maps specific internal ip ranges to specific availability zones, and even more precisely by instance type
- Experiments:
 - using external probes to identify responsive public IPs in the EC2 public cloud, then finding the internal IP addresses for those public IPs using DNS queries.
 - Launching various instance types on EC2 and recorded the IPs that were assigned to each instance by types

Results:

- Availability zones use separate physical infrastructure
 - each zone are assigned IP addresses from disjoint portions of the observed internal address space
- Launched 100 instances (20 each type, 39 hours after terminating the account A instances) in zone 3 from a second account
 - no ip addresses were ever observed being assigned to more than one instance type
 - of the 100 account B Ip's, 55 were repeats of ip addresses assigned to instance for account A

Co-Residency

- Networked based co residence checks
 - matching domain 0 (Dom0) IP address - In EC2 the Dom0 VM manager VM is configured to route packets for its guest images and reports itself as a hop in traceroutes
 - small packet round trip times (RTT) - Vms are likely to be closed to each other if the RTT is small
 - Numerically close internal IP addresses - within seven sequential IP addresses.

Exploiting placement

- Attacker could more sophisticatedly leverage cloud cartography to precisely coreside on the same machine as their target versus a brute force attack
- Strategy:

- brute force strategy: attacker simply launch many instances over a relatively long period of time. Such a naive strategy already achieves reasonable success rates (though for relatively large target sets)
- Refined strategy: attacker target recently-launched instances, taking advantage of the tendency for EC2 to assign fresh instances to the same small set of machines
- Refind strategy achieves co-residence iwth a specific (m1.small) instnace almost 50% of the time

Cross VM INformation Leakage

- denial of service (DoS)
- Stealing cryptographic keys
- estimate target's workload
 - cache **COME BAC

Guaranteed NO Co-resdiency

- Many orgs have service level agreement (SLA) that guarantee physical isolation
 - the entire physical machine is dedicated to a single org
 - Problem: how can the org verify that they have sole access to the physical device
 - Solution: The homeAlone VM
- Methodology: HomeAlone detection system (CACHE PRIME-PROBE)
 - PRIME: read large section fo main memory to fill up a section of the cache
 - IDLE - wait a period of time to allow other VM's to run and potentially use the cache
 - PROBE: reread the same section and compare access time to determine if the watched section of cache was overwritten
 - Uses 1/16th of available cache to test
- Assumption: friendly VM will avoid using certain portion of the cache

VM Classification

- Friendly
 - another vm running by the same org. Expected and wanted
- Foe
 - another Vm not from same ORG . it should not be on the same physical machine
- Benign Foe
 - not actively attacking, may or may not be aware of other VMs
 - Result of accidental or purposeful breach of SLA physical isolation
- Adversarial Foe
 - Actively attempting to exploit co residency

- attempting to disrupt or gather information through L2 cache side-channel

How to detect?

- Choose a set of cache to monitor (#7) tell all friendly VM
- Gather Activity profiles from friendly VM
- Copy the data in #7 to reserved
- Whenever #7
- Read data from memory into num 7
- wait long enough to allow other VMs to access cahche
 - in this case only foe Vm access num 7 directly, no friendly vm uses num 7

April 22nd | Day 5

Identity Management

- a process of managing individual, entities, or group authentication, authorizaiton, roles, privileges, etc, across the system
- makes sense to make identity management centralized
 - identity = can be tracked and managed across all applications
 - security: can be set uniformly across all application
 - cost control = reduce or eliminate duplicated identity management
- Research shows that the increase complexity and inflexibility of centralized approach outweighs the cons
 - even with the introduction of blockchain for itentity management

Key concepts

- Activation
 - refer to the creation of user identity
 - one time event = create identity and assign priviliages
- Authentication
 - refer to the process of verifying the identity of some users
 - The credentials usually comprised with a public known part and one/more secrets
- Authentication Strength
 - authentication is the first line of defense to access application and sensitive data
 - in general, the more secrets that are required, the more secure the scheme is (?)
 - multi-factor authentication: 2+ factors of something you know, something you have,

and something you are.

Authentication methods:

- Authenticate each and every service at request time
 - password based auth
 - 2fa/MFA
 - biometric auth
 - knowledge based auth
 - behavioral auth
- Preauthenticate in advance and use the temp access token for each subsequent request
 - single sign on
- both
 - token based auth
 - certificate based auth

Password based authentication

- the most common/traditional method of verifying a users' identity. IT works by having a user enter a username or email and a password to gain access to a system, service, or application
- pros:
 - simple and easy to implement
 - no special hardware required
 - ubiquitous - used in almost all systems
- Cons:
 - weak passwords are easy to guess or brute-force
 - password reuse across sites increases risk
 - phishing attacks can trick users into revealing credentials
 - password databases can be leaked if not secured properly
 - forgotten passwords lead to support overhead.
- Password strength is key, one of the most difficult challenges in security

Knowledge based authentication

- an authentication method that verifies a users' identity based on something the user knows, typically personal information or answers to pre-set questions
- Static KBA
 - user sets answers to pre-defined questions during registration
 - "What's your mother's maiden name" "What was the name of your first pet?"

- Dynamic KBA
 - system-generated questions based on public or private data sources (no prior setup by the user)
 - Examples: "Which of these addresses have you lived at?" "Which car did you own in 2018"
- Use cases: account recovery

What Happened in Account Recovery?

- suppose you forget the password for your account,
 - initiate the password recovery process
 - input the communication channel that is associated with the account you try to recover (email)
 - obtain a temporary link for account recovery
 - reset your password through that link
- Email Addys serves as a master key for all accounts
 - master key should be private at all time, only the owner has access to the master key
 - is this true in real life?

Multi-factor auth

- 1 auth factor (knowing password) aint enough to protect the accounts
- MFA requires users to provide two or more types of credentials before gaining access to cloud services
 - something you know, have, are
- Common MFA methods used in the cloud
 - SMS or email verification codes
 - authenticator apps (google authenticator)
 - biometric verification (finger print, facial recognition)
 - people hate it, but it is a reasonable usability sacrifice for enhancing account security

Token Based Authentication:

- token based authentication is a common and secure method for controlling access to APIs
 - allows clients to authenticate once and use a token for subsequent requests
- How it works
 - logging and Authentication: The user logs in with valid credentials
 - token issued: if the credentials are correct, the server issues a token (usually a JSON web Token - JWT or an opaque token)

- access to API with token: the client includes the token in the authorization header (Authorization: Bearer) when making API requests
- Token validation: the api checks the token's validity. if it's valid, the request processes, if not it is rejected
- Token Expiry/Renewal: tokens usually expire after a set time (15 min, 1 hour) for security. Clients may use refresh tokens to get new access tokens without logging in again
- Don't leave access token in code commit

Single sign ons:

- Allows users to log in once and gain access to multiple cloud applications and services without needing to log in again for each one
- How SSO works:
 - user logs in through an identity provider (IdP) like Okta, Azure AD, or google identity
 - The IdP authenticates the user and issues a token or session (often using standards like SAML, OAuth, or OpenID Connect)
 - the token is used to access multiple Service Provider (SP)
 - When the user tries to access a new service, the system recognizes the session and grants access without requiring a new login.
- Why SSO is important
 - improved user experience: users don't need to remember separate credentials for each cloud app
 - centralized Authentication: IT teams manage all access through a single identity system.
 - enhanced security: reduces password fatigue and risky behaviors (like password reuse)
 - Access control and compliance: easier to enforce access policies and track who accessed what

Single Sign on:

- identity provider serves as a master key for all accounts
 - a master key should be private at all time, only the owner has access to the master key
 - is this true in real life?
- Email provider serves as identity provider
 - can email provider serve as a master key?

Other authentication schemes

- Biometric Authentication
 - fingerprint recognition - scans the ridges and patterns on a fingertip.
 - Facial recognition - analyzes facial structure and features
 - Iris or retina scan - captures unique patterns in the eye
 - voice recognition - uses vocal patterns and tone
- Behavioral Authentication
 - typing patterns - speed rhythm, and pressure when using a keyboard
 - mouse movements - direction, speed, and clicks
 - Touchscreen behavior - swipe speed, pressure, gestures on mobile
 - gait analysis - how a person walks (in wearables)
 - app usage habits - frequent actions or app navigation patterns device orientation and handling - how a person holds or tilts their phone
- Not suitable in cloud applications

In Conclusion

password remains the most practical methods in authentication

simple and easy to implement

no special hardware required

ubiquitous - used in almost all systems

Many authentication schemes depend on password

multi factor

token based : need password to log in and obtain token

SSO: need password to log in to identity provider

Why we don't like password

people are lazy

passwords are easy to crack "password", DOB, CWID

Zero Knowledge Authentication

users can prove their identity without revealing their actual secret to the system.

- using a zero knowledge proof (ZKP)

- How it works
 - the user registers securely by providing a public commitment to their secret.
 - During login, the user generates a cryptographic proof using their secret.
 - the server verifies the proof without ever seeing the secret itself.
 - if the proof is valid, access is granted

The Ali Baba Cave

- Victor build a ring cave, with the entrance on one side and the magic door blockign the opposite side

- label them A and B
- Victor waits outside the cave as peggy goes in
 - peggy takes either path A or B
 - Victor is not allowed to see which path she takes
- Victor enters the cave and should the name of the path he wants her to return
 - chosen at random
- the two scenarios:
 - if peggy knows the magic word, this is easy, she opens the door if necessary and returns along the desired path
 - if she did not know the word. she would only be able to return from the path that she went in.
- Since Victor would choose A or B at random, she would have a 50% chance of guessing correctly.
 - repeat this trick many times, her chance of successfully anticipating all of Victor's requests would be approximately 0.
- if peggy repeatedly appears at the exit Victor names, then he can conclude that it is extremely probable that Peggy knows the secret word

Two Balls and the color blind friend

- imagine two friends, peggy and victor,. Peggy knows victor is colorblind and hands him two identical balls except one is green and the other is red.
 - They agree the balls are exactly identical apart from their color, which victor can not evaluate
 - Peggy (prover) claims that she can prove to victor (verifier) that the balls have indeed different colors without revealing which is which.
- Victor takes the two balls, puts them behind his back, shuffles them, and again shows them to peggy.
 - he knows whether he has switched the balls or not since he shuffled them consciously.
 - furthermore, peggy knows as well because she can differentiate between the colors
 - she then tells him that he switched, which is an indication that the balls have to be differently colored.

Sudoku

- we can describe the puzzle by a set of vectors of the type (i, j, k) all are between 1-9
 - 3 1 8 means row 3 column 1 with number 8
- peggy is the first to find a solution and wants to prove to victor that she solved it without revealing the solution
- mask the entire board, only shows known number

- victor randomly chooses a row, column or box
- peggy collects all nine cards of this column, shuffles them, and hands them to victor. he can then look at the cards and check whether constraint holds
- victor makes a query, randomly chooses a row, column or box and peggy's response is handing him the respective cards, which he can then verify

Day 6 APRIL 27th

Datacenter - level risks

-Physical security risks

natural disasters - earthquakes, floods, fires, etc, can physically destroy infrastructure

hardware theft/tampering - physical removal or modification of servers can lead to data breaches

Software level security risks

- hypervisor attacks - exploiting vulnerabilities in virtualization platforms to gain control over VMs.

- Configuration errors - Misconfigurations can expose sensitive data or create attack vectors

- Network level risks
- insider threats
- environmental and operational risks
 - Power over-subscription - too many devices drawing power simultaneously can lead to failure or outages.
 - Cooling system failure - leads to overheating and hardware degradation.

What Really happened?

-With the ever-increasing demand of cloud services, data centers have experienced significant growth in their scale

the rapid server deployment in data centers has caused their power distribution and cooling systems to approach peak capacity

upgrading power and thermal system is really expensive, commonly in hundreds of millions of dollars

Power Oversubscription

-to place more servers on the power infrastructure of a data center than it can support

-assume all the servers would not reach their maximum power consumption simultaneously

-Allows many more servers to be hosted, without the need of upgrading the power infrastructure

-Thermal Regulations

- the cooling cost has reached 24% of a data center's budget

- Increasing the supply air temp by merely 1C can save approximately 2-5 percent of the cooling power

- Temperature increment forces the servers to run in a hotter environment

Power-Intensive Workload

- Different workloads yield very different power consumptions
 - even when they are all running with 100% CPU utilization
- SPECCPU2006

CPU utilization cannot fully reflect the power consumption of the server

Threat model

- The target is running certain cloud services that are available to public.
- IaaS, PaaS and SaaS
- Any user including an attacker can subscribe the services
 - The target data center deploys power oversubscription as its power

Power Attack:

- Achieve coresidency with target VM
- Run power intensive workload on VMs around the target
- Trigger power oversubscription by peaking all VM at the same time

Other Power intensive workloads

-VM Migration

- VM migration is executed when a vm is under heavy load and cloud provider decides to move it to another location with less utilization
- however, VM migration consumes a lot of power on both source location and target location
 - CPU cache and floating point operation

Thermal Regulation

- Data centers set the supply air temp automatically based on the workload
- A recent study shows that the increasing the supply air temp by meanrely 1C can save approximately 2-5% of the cooling power
- Thus there is a trend in data centers toraise the highest set temp from 75F to 85F or even higher
- Under the reduced cooling redundancies, an accidental synchronization of running intensive workloads **COME BACK()**

Thermal Intensive workload

- Different worklaods yield very different thermal dissipation
- Even when they are all running with 100% CPU utilization
- SPECCPU2006

Other thermal characteristics

- Thermal residue
- When a workload finished executing, temperature remains (temperature gap)

If Successful..

- CPU throttling

- CPU will automatically throttle down if it is running in a hot environment

- This affect the entire data center

- Device failure

- CPU and Storage

COME BAK